Cardiac CT Training
Massachusetts General Hospital
Cardiovascular CT Core Laboratory
www.CVImagingCore.org

Free SNOMED Browser
Use Dataline's Snoflake browser to look up clinical terms for free.
www.snoflake.co.uk

Gefahr für Ihr Herz
Die 5 gefährlichsten Lügen, die Ihnen Ihr Arzt erzählt !
www.fid-gesundheitswissen.de

Technology Review

"Die Russen sind wirklich gut"

20.05.09
Infotech | Sicherheit

Von Gordon Bolduan


Bild: David Poblador (cc-by-sa 2.0)

Giovanni Vigna kommt aus Italien, ist 39 Jahre alt und organisiert alljährlich den weltweiten Hacker-Wettbewerb "Capture the flag" (ICTF). Nach seinem PhD-Abschluss in Mailand forschte er in den USA als Post Doc auf dem Gebiet der IT-Sicherheit und erhielt schließlich eine Professur am Lehrstuhl für Informatik der University of California Santa Barbara. Bereits mit 14 Jahren experimentierte er am Commodore 64 und anderen Heimrechnern der ersten Generation und beackert sein Fachgebiet nach eigenen Angaben auch heute noch mit großer Leidenschaft. Technology Review sprach mit ihm über die Organisation des iCTF und die dabei gemachten Beobachtungen.

Technology Review: Können Sie kurz das Thema des im Dezember abgehaltenen iCTF-Wettbewerbes umreißen?

Giovanni Vigna: Das Schlagwort wäre "Angriff auf ein Cyber-Terroristennetzwerk" sagen. Ein ziemlich unglücklicher Zufall: Während wir an dem Konzept arbeiteten, war dieser Terroranschlag in Indien. Das ließ mich innehalten und überlegen, ob das nicht vielleicht die Grenzen des guten Geschmacks überschreitet. Unsere Arbeiten waren zu dem Zeitpunkt allerdings schon recht weit fortgeschritten. Wir wurden aber beruhigt, dass wohl niemand annehmen würde, wir fänden Terrorismus spaßig. Unsere Story: Die Teams sollten in das Netzwerk der Terroristen eindringen und eine Bombenexplosion verhindern.

TR: Wie kommen Sie auf solche Geschichten?

Vigna: Das hebt unseren Capture-the-Flag-Wettbewerb von den anderen ab, insbesondere von dem von DEFCON. Wir entwickeln ein Thema und legen alle Services, Webseiten um dieses Szenario herum an. Im ersten Jahr lautete das Thema: "Microsoft Windows wird Open-Source-Software". Dann die weltweite UN-Wahl 2014. Gefolgt von der Mafia-Website, der Hillbilly-Bank und dem Spammer-Museum. Wir setzen uns im Vorfeld zusammen und überlegen uns ein interessantes, unterhaltsames, harmloses Thema, entwickeln die Geschichte dazu und schreiben den Text. Diesen Part übernehme ich in der Regel selbst.

TR: Werden wir bald einen Cybercrime-Thriller von Ihnen lesen?

Vigna: Nein, eigentlich nicht. In einer Unterhaltung mit einem Hollywood-Drehbuchautoren schlug dieser vor, ich solle ein Drehbuch darüber schreiben, dass die Teams denken, sie nehmen an einem Wettbewerb teil. In Wirklichkeit aber handelt es sich um einen echten Hacker-Angriff. Ich habe die Idee aufgegriffen. Tatsächlich habe ich für den diesjährigen Wettbewerb die Website www.softerror.com erstellt.

TR: Glichen auch die Anfänge des iCTF auch einem Hollywood-Film?

Vigna: Es fing im Jahr 2001 an, als ich meinen Lehrauftrag an der University of California, Santa Barbara annahm. In einem Graduiertenkolleg zum Thema Sicherheit überlegten wir uns eine Art von Wettbewerb, um das Erlernte in der Praxis anzuwenden. Ich richtete dafür zwei Netzwerke im Kurs ein. Dann teilte ich die Teilnehmer in zwei Gruppen auf: die eine Hälfte waren die Angreifer, die andere Hälfte sollte diese Angriffe abwehren. Das fand also kursintern statt und war unser erstes Experiment dieser Art. Die Studenten fanden das Konzept toll, räumten aber ein, dass sie sowohl Angriff als auch Abwehr ausprobieren wollten.

TR: Auf welche Weise erfolgte die Implementierung? Waren die Studenten im selben Zimmer?

Vigna: Ja, in der Tat. Es war alles lokal, nichts verteilt. Mehr LAN geht nicht, wenn man so will. Wir wollten die Probleme ermitteln. Das war alles noch vor dem eigentlichen CTF-Wettbewerb, der weitaus größere Ausmaße angenommen hat. Wir wollten herausfinden, was passierte, welche Probleme bestanden, wie die Treffer gezählt werden usw. Andere machten sich parallel zu uns ähnliche Gedanken dazu. Unser Konzept war aber anders als das der Hacker-Wettbewerbes DEFCON.

TR: Wie sah das aus?

Vigna: Das war ein serverbasierter Ansatz. Bei diesem Wettbewerb wurde Sieger, wer als Erster in das System eindrang und zeigte, dass die Sicherheitsmaßnahmen geknackt wurden. Es gab also ein konkretes Ziel und ein Wettrennen darum, es vor allen anderen zu erreichen, also vor allen anderen den Computer zu knacken.

TR: Warum haben Sie die Veranstaltung zunächst auf die USA beschränkt und später international angelegt?

Vigna: Gute Frage, mir fällt darauf eigentlich keine Antwort ein.

TR: Wollten Sie die Russen herausfordern?

Vigna: Nein! (lacht) Anfangs wusste ich von einer Reihe von Kollegen in den USA, dass sie in Graduiertenkollegs das Thema Sicherheit unterrichteten. Es bot sich also an, mit amerikanischen Universitäten zu beginnen. Später erfuhren auch andere von dem Wettbewerb, und ich traf mich mit europäischen Kollegen, die auch mitmachen wollten. Eines der Probleme, die ich darin sah, war die Zeit. Wir fangen um 8 Uhr morgens an. Dann ist es in Europa schon 17 Uhr, und ich dachte, dass die Studenten keine Lust hätten, zu diesen Zeiten zu arbeiten.

TR: Sie änderten diesmal das gesamte Konzept. Warum?

Vigna: Wir haben festgestellt, dass sich Teams wie Squareroots, ENOFLAG, We_0wn_Y0u und 0ldEur0pe, insbesondere die deutschen Teams, unglaublich gut auf den Wettbewerb vorbereiten. Sie haben Tools, Filter – schlicht alles, was einen guten Hacker ausmacht. Aber sie wissen auch, wie der Wettbewerb abläuft, was ihnen einen gewissen Vorteil gegenüber jenen Teams verschafft, die zum ersten Mal dabei sind.

TR: Sie haben also mehr Erfahrung?

Vigna: Genau. Das Team der UCSB, das in der Regel aus Studenten meines Kurses besteht, bildet oft das Schlusslicht. Keine Frage, das sind gute Studenten, die die ganzen Aspekte rund um das Thema Sicherheitslücken in zweieinhalb Monaten intensiv beigebracht bekommen. Und dann werden sie in die Löwengrube CTF geworfen und im Bruchteil einer Sekunde von den anderen in der Luft zerrissen.

TR: Können Sie einen Zusammenhang zwischen den Kenntnissen und dem Herkunftsland der Teilnehmer erkennen?

Vigna: In der Tat. Im Allgemeinen sind die Russen wirklich gut. Das Gleiche gilt für die Deutschen.

Vielleicht investieren sie mehr Zeit oder werden anders geschult. Eine der spannendsten Untergrundbewegungen kam immerhin aus Deutschland. Ich sehe in dieser Richtung tatsächlich gewisse Zusammenhänge. Ebenso gibt es Tendenzen, dass Teams aus anderen Ländern, die früher nicht so gut abschnitten, deutliche Fortschritte machen. Beispielsweise ein italienisches Team bei der DEFCON. Ich würde dort gern einmal Teams wie Squareroots oder ENOFLAG sehen, dieser Wettbewerb ist ja anders, etwas intensiver.

TR: Inwiefern?

Vigna: Es gibt eine Qualifikationsrunde, an der ungefähr 200 Teams teilnehmen. Aber nur die ersten 7 werden zur DEFCON eingeladen.

TR: Die Elite also?

Vigna: Ja, die Hacker-Weltmeisterschaft, wenn man so will.

TR: Wenn ich den iCTF meistere, gehöre ich nicht zur Elite?

Vigna: Man kann es so formulieren: Sie sind gut darin, sicherheitsbezogene Puzzles zu lösen.

TR: Was macht ein Top-Hacker denn aus?

Vigna: Ein guter Hacker sieht sich ein System an. Dabei kann es sich um eine Software, ein Netzwerk oder einen Service handeln. Und der Hacker begreift – quasi durch Re-Engineering – die Funktionalität des Services. Er erkennt die Annahmen, von denen der Service ausgeht. Und bei diesen Annahmen setzt er dann an: Er verletzt sie, um die Sicherheitsmaßnahmen auszuhebeln. Was ich also meinen Schülern in meinen Vorlesungen zur Schwachstellenanalyse versuche beizubringen: Schaut euch an, was dieses Programm macht. Versucht herauszufinden, welche impliziten Annahmen gemacht werden, welche Checks nicht gemacht werden, weil davon ausgegangen wird, dass der Code auf bestimmte Weise funktioniert. Dass beispielsweise benutzerseitige Eingaben nie ein Semikolon enthalten werden. Und wenn ihr so etwas gefunden habt, greift diese Annahmen an, um die Schwachstellen aufzudecken. Diese Art von Analyse, die Analyse von Schwachstellen, bildet die Grundlage für nahezu alle Sicherheitsarbeiten. Danach kommen Analysen zum Einrichten der Sicherheitsinfrastruktur. Die sind auch sehr wichtig.

TR: Aber Sie lassen auch angreifen? Warum?

Vigna: Es ist wichtig zu wissen, wie man einen Service angreift, denn nur wer genau weiß, wie sich eine Schwachstelle nutzen lässt, kann auch die richtigen Schutzmaßnahmen entwickeln. Klassisches Beispiel: Jemand, der einen Wandsafe baut. Sie glauben doch nicht, dass diese Leute nicht wüssten, wie man einen Safe knackt? Natürlich wissen sie das.

Und genau deshalb bauen sie die entsprechenden Sicherheitsfunktionen ein, die es Dieben unmöglich machen, den Safe aufzubrechen. Und IT-Mitarbeiter, die sich Sicherheitsexperten schimpfen, aber gleichzeitig einräumen, sie wissen nicht, welche Remote-Sicherheitslücken es beim Integrieren von PHP-Dateien gibt, werden mit ziemlicher Sicherheit Fehler machen und PHP-Dateien mit der falschen Konfiguration installieren, wodurch Sicherheitslücken entstehen.

TR: Keine Angst, dass Ihre Studenten ihr Wissen auf kriminelle Weise nutzen?

Vigna: Das hängt von den ethischen Werten ab, die die Leute haben. Ich habe darauf keinen direkten Einfluss. Ich bringe die Inhalte meinen Studenten bei und muss darauf vertrauen, dass sie sie für gute Zwecke einsetzen. Wenn man es so nimmt, kann auch jeder einen Baseballschläger kaufen. Der dient dazu, Baseball zu spielen. Aber niemand kann verhindern, dass jemand den Schläger nimmt und damit einen anderen Menschen erschlägt.

Was soll man denn dann machen? Den Leuten nicht mehr beibringen, wie man Baseball spielt? Oder wie man einen Baseballschläger benutzt? In meinen Vorlesungen verwende ich übrigens eine Menge

Zeit darauf, ethische Aspekte anzusprechen. Was ist legal, was ist illegal? Wie werden diese Sicherheitstests ausgeführt? Im eigenen Netzwerk, nicht in fremden. Und das ist ziemlich effektiv. Ich hatte in dieser Hinsicht noch nie irgendwelche Probleme mit meinen Studenten.

(**bsc[1]**/Technology Review)

URL dieses Artikels:
http://www.heise.de/tr/artikel/137937

Links in diesem Artikel:
[1] mailto:bsc@tr.heise.de

Copyright © 2009 Heise Zeitschriften Verlag Datenschutzhinweis Impressum Kontakt
International: The H, The H Security, The H Open Source, heise online Polska, heise Security Polska, heise Open Source Polska, heise Networks Polska